TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Cisco ASA and FTD VPN flaw exploited to crash firewalls; fix released

From **Cybersecurity Briefing** · 2026-10-28 to 2026-10-29 (last 24 hours) · Briefing generated 2026-10-29

REPORT ID	VERSION	HANDLING
CTI-20261029-01	1.0 · 2026-10-29 08:35 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-28	No update
CVES	**ANALYST**	
CVE-2026-76418 (CVSS 8.6)	Nick Sturgeon	

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: HIGH

BOTTOM LINE UP FRONT

On 28 October 2026 Cisco published advisory cisco-sa-asaftd-tunnel-dos-s6mgkb75 for CVE-2026-76418 (CVSS 3.1 8.6, High; bug CSCwx26625). The flaw is in the Remote Access SSL VPN service of Cisco Secure Firewall ASA Software and Secure Firewall Threat Defense (FTD) Software. Cisco attributes it to logic errors when secondary authentication is configured on a tunnel group. An unauthenticated remote attacker can send a crafted request while connecting to the SSL VPN and force the firewall to reload, which causes a denial of service. Cisco PSIRT says it learned of active exploitation in October 2026 [S1] [S2]. The briefing could not corroborate the CVE ID at first. It is now confirmed by the Cisco advisory and the CVE record, which Cisco as CNA published on 2026-10-28 [S1] [S2]. CVE-2026-20349 is a different flaw from August 2026 [S7] [S8].

A device is exposed only when three things are all true: it runs an unfixed release, its SSL VPN login service is reachable (webvpn enabled on an interface), and a relevant tunnel group, including DefaultWEBVPNGroup, has secondary-authentication-server-group configured. A successful VPN login is not needed to reach the vulnerable code path [S1] [S4] [S6]. Cisco lists fixed ASA releases (9.16.4.104, 9.18.4.96, 9.20.4.50, 9.22.3.200, 9.23.1.48, 9.24.1.27/9.24.10.1) and fixed FTD releases (7.0.11, 7.2.13, 7.4.9, 7.6.7, 7.7.14, 10.0.3, 10.1.1). Cisco says there is no workaround. It offers two temporary mitigations: disable the tunnel group list, or remove secondary authentication. The second weakens remote-access VPN security [S1] [S3].

This is the second Cisco firewall VPN denial-of-service zero-day since August. CVE-2026-20349, an HTTP request handling flaw in the same SSL VPN service, was patched and added to CISA KEV on 2026-08-11 [S4] [S7] [S8] [S11]. Cisco has not said who is exploiting CVE-2026-76418, how widely, or since when, and has not published indicators of compromise [S1] [S5]. BleepingComputer cites Shadowserver tracking more than 51,000 internet-exposed ASA SSL VPN devices, but not how many have secondary authentication enabled [S5]. CISA's KEV catalog version 2026.10.28 did not list CVE-2026-76418 when this report was written [S9], and no EPSS score had been published yet [S10].

Impact is limited to availability: there is no reported code execution or data theft [S6]. Even so, repeated reloads take down remote access for staff, clinicians and vendors, and can break HA pairs. Defenders should confirm exposure using the configuration checks in Cisco's advisory and upgrade every affected ASA/FTD, including both members of failover pairs. Where patching must wait, apply Cisco's mitigation and limit who can reach the VPN portal. Watch for unexpected reloads and keep crash files for Cisco TAC [S1] [S11].

Key judgments

LIKELY · MODERATE CONFIDENCE
CISA will likely add CVE-2026-76418 to the KEV catalog within the next two weeks, because the vendor has confirmed in-the-wild exploitation and CISA added the comparable CVE-2026-20349 on the same day as its advisory. [S1] [S8] [S9]

VERY LIKELY · MODERATE CONFIDENCE
Unpatched ASA/FTD devices with SSL VPN and secondary authentication enabled will very likely face more forced-reload attempts over the coming weeks, as public fixed-release information helps others identify the vulnerable logic. [S1] [S4] [S5]

UNLIKELY · MODERATE CONFIDENCE
It is unlikely that CVE-2026-76418 will turn out to allow code execution or data theft on its own. The vendor scoring (C:N/I:N/A:H) and CWE-690 (NULL pointer dereference) point to a crash-only condition. [S1] [S2]

LIKELY · LOW CONFIDENCE
Cisco will likely disclose at least one more exploited ASA/FTD remote-access VPN flaw within the next six months, given two exploited VPN denial-of-service zero-days since August 2026 and the platform's history of exploitation (ArcaneDoor, CVE-2025-20333/20362). [S4] [S5] [S7]

INDICATORS OF COMPROMISE

Cisco and every news source reviewed state that no indicators of compromise were published for CVE-2026-76418, as of 2026-10-29. The entries below are configuration and exposure markers taken from Cisco's advisory, plus derived network locations for the SSL VPN service. They are not attacker infrastructure.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`webvpn / enable <interface_name>`	Running-config lines showing the SSL VPN service is enabled on an interface, which is a required condition for exposure.	REPORTED	2026-10-28	[S1] [S6]
command	`secondary-authentication-server-group`	Tunnel-group setting that makes the device vulnerable. Check every tunnel group, including DefaultWEBVPNGroup and profiles not shown on the login page.	REPORTED	2026-10-28	[S1] [S6]
command	`tunnel-group-list enable`	If present, every tunnel group must be reviewed for secondary authentication. If absent, DefaultWEBVPNGroup is still in scope.	REPORTED	2026-10-28	[S1]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`no tunnel-group-list enable`	Cisco mitigation (WebVPN mode) for when DefaultWEBVPNGroup does not use secondary authentication. Users must then know the correct connection profile name.	REPORTED	2026-10-28	[S1] [S3]
command	`no secondary-authentication-server-group`	Cisco mitigation for when DefaultWEBVPNGroup uses secondary authentication. It weakens remote access VPN security, so use it only as a temporary last resort.	REPORTED	2026-10-28	[S1] [S6]
command	`show running-config webvpn ; show running-config tunnel-group`	Derived: standard ASA CLI commands for checking the configuration conditions Cisco describes. The advisory itself lists no show commands.	DERIVED		[S1]
port	`TCP/443`	Derived: the default listener for the ASA/FTD SSL VPN login service, which is where the crafted request must arrive. Deployments may use a custom port.	DERIVED		[S1]
http-request	`/+CSCOE+/logon.html`	Derived: the standard ASA/FTD WebVPN/AnyConnect login portal path handled by the SSL VPN service. Cisco has not disclosed the exact request used in the exploit, so treat this as the attack surface to monitor, not a confirmed exploit signature.	DERIVED		[S1]
other	`Cisco bug ID CSCwx26625`	Defect ID for CVE-2026-76418. Use it when opening TAC cases or checking release notes.	REPORTED	2026-10-28	[S1] [S2]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

An unauthenticated attacker connects to the Remote Access SSL VPN login service of an ASA or FTD firewall and sends a crafted request to a tunnel group that has secondary authentication configured. Logic errors in that path (classified as a NULL pointer dereference, CWE-690) crash the device and force a reload, which drops all VPN sessions and traffic passing through the firewall. No login is required, and the attack can be repeated to keep the device unavailable. Cisco has not disclosed attacker tooling, infrastructure or targeting [S1] [S2] [S4].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Inferred: attackers need to find internet-reachable ASA/FTD SSL VPN portals, of which Shadowserver tracks more than 51,000. No scanning activity specific to this CVE has been reported. [S5]	Watch for repeated hits on VPN portal paths from unfamiliar sources, and use external attack-surface tools to inventory exposed portals.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	A crafted request to the SSL VPN service during connection reaches the secondary-authentication tunnel-group logic and causes the device to reload. [S1] [S2] [S3]	Alert on unexpected ASA/FTD reloads, failover events and gaps in syslog. Keep crashinfo files and correlate with inbound VPN portal connections just before the crash.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Cisco ASA/FTD syslog silence (possible reload) `KQL`

```
CommonSecurityLog
| where TimeGenerated > ago(7d)
| where DeviceVendor == "Cisco" and DeviceProduct in ("ASA", "Firepower", "FTD")
| summarize Events = count() by Computer, bin(TimeGenerated, 5m)
| order by Computer asc, TimeGenerated asc
| serialize
| extend PrevTime = prev(TimeGenerated), PrevHost = prev(Computer)
| where Computer == PrevHost and TimeGenerated - PrevTime > 10m
| project Computer, GapStart = PrevTime, GapEnd = TimeGenerated, GapMinutes = datetime_diff('minute',
TimeGenerated, PrevTime)
```

Finds gaps in firewall log flow that may indicate a crash and reload. Tune the threshold to each device's normal log volume, and correlate with maintenance windows and failover events.

Cisco ASA restart / crash text in syslog `SPLUNK SPL`

```
index=network sourcetype=cisco:asa ("reload" OR "crashinfo" OR "Restarting" OR "Failover" OR "traceback")
| stats count earliest(_time) as first latest(_time) as last values(_raw) as samples by host
| convert ctime(first) ctime(last)
```

A generic keyword hunt for reload and crash artifacts. Message wording differs between ASA and FTD versions, so tune it to your local syslog. Cisco has published no exploit-specific syslog signature.

High-rate connections to ASA/FTD SSL VPN portal from a single source `SPLUNK SPL`

```
index=network (sourcetype=cisco:asa OR sourcetype=pan:traffic OR sourcetype=netflow) dest_port=443 dest IN ("
<asa_vpn_ip_1>","<asa_vpn_ip_2>")
| bin _time span=5m
| stats dc(src_port) as conns by _time, src, dest
| where conns > 50
| sort - conns
```

Placeholder destination IPs. Exploitation may need only one request, so this mainly finds probing and repeated crash attempts. Correlate any hits with reload times.

Inbound requests to ASA WebVPN logon path (attack surface monitoring) `SURICATA`

```
alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"POLICY Inbound request to Cisco ASA/FTD WebVPN logon
path"; flow:established,to_server; http.uri; content:"/+CSCOE+/"; startswith; threshold:type both, track
by_src, count 20, seconds 60; classtype:policy-violation; sid:9007641; rev:1;)
```

Works only where TLS is decrypted in front of the firewall, which is rare. This is a volume and visibility rule, not an exploit signature. Cisco Snort rules for the earlier CVE-2026-20349 were 46897 and 59654. Check Talos for rules covering CVE-2026-76418.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Cisco Secure Firewall ASA Software	Releases before the first fixed release in each train (9.16 and earlier through 9.24) with webvpn enabled and secondary authentication on a tunnel group	9.16.4.104; 9.18.4.96; 9.20.4.50; 9.22.3.200; 9.23.1.48; 9.24.1.27 / 9.24.10.1	CVE-2026-76418	8.6 (AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H)	Not yet published (no score returned by FIRST API on 2026-10-29)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Cisco Secure Firewall Threat Defense (FTD) Software	7.0 and earlier through 10.1 releases before the first fixed release, with remote access SSL VPN and secondary authentication on a tunnel group	7.0.11; 7.2.13; 7.4.9; 7.6.7; 7.7.14; 10.0.3; 10.1.1	CVE-2026-76418	8.6	Not yet published	No	N/A
Cisco ASA / FTD (related August 2026 flaw)	Devices with SSL VPN, IKEv2 client services, or ZTNA (FTD) enabled on releases before the August fixed releases	ASA 9.16.4.103, 9.18.4.94, 9.20.4.49, 9.22.3.26, 9.23.1.47, 9.24.1.26; FTD 7.0.10, 7.2.12, 7.4.8, 7.6.6, 7.7.13, 10.0.2, 10.1.0	CVE-2026-20349	8.6	0.0101 (63rd percentile, 2026-10-28)	Yes (added 2026-08-11)	Unknown (not retrieved)

Immediate (0–24 hours)

- Inventory every ASA and FTD device, including both members of HA/failover pairs. Check whether webvpn is enabled on any interface and whether any tunnel group, including DefaultWEBVPNGroup, has secondary-authentication-server-group configured. On FTD, review the deployed RA VPN policy in FMC or FDM. `IT OPS` [S1] [S6]
- On exposed devices that cannot be upgraded today, apply Cisco's temporary mitigation. Use 'no tunnel-group-list enable' if DefaultWEBVPNGroup lacks secondary authentication. Otherwise remove secondary authentication, and document the risk this creates. `IT OPS` [S1] [S3]
- Add alerting for unexpected ASA/FTD reloads, failover events and syslog gaps. Preserve crashinfo files and open a TAC case referencing CSCwx26625 if a crash occurs. `SOC` [S1] [S11]
- Notify leadership and help desks that remote-access VPN outages are possible, and confirm backup remote-access paths for critical staff. `LEADERSHIP` [S4]

Short term (1–7 days)

- Upgrade all affected ASA/FTD devices to the first fixed release for their train, or later. Use Cisco Software Checker to confirm the target also includes the August fixes for CVE-2026-20349. Patch the standby unit first, then fail over. `IT OPS` [S1] [S6] [S7]
- After upgrading, reverse any temporary mitigation that removed secondary authentication, so MFA protection on VPN logins is restored. `IT OPS` [S1]
- Hunt back through October 2026 for unexplained firewall reloads and correlate them with inbound VPN portal traffic. `SOC` [S1] [S4]
- Track CISA KEV and Cisco's advisory for updates such as KEV listing, IOCs or new fixed releases. `SOC` [S9] [S1]

Long term

- Restrict SSL VPN portal reachability to known source ranges or countries where the business allows it, and decommission unused VPN gateways and connection profiles. `IT OPS` [S11]
- Set a standing process to apply ASA/FTD security fixes within days of release, since exploited flaws on this platform have recurred (ArcaneDoor 2024, CVE-2025-20333/20362, CVE-2026-20349, CVE-2026-76418). `LEADERSHIP` [S5]
- Plan resilient remote access: keep a secondary VPN headend or ZTNA path so that one crashing firewall does not cut off all remote work. `LEADERSHIP` [S4]

Workarounds & compensating controls

- Where available, use upstream filtering or rate limiting in front of the VPN portal (ISP or cloud DDoS service) to blunt repeated crash attempts from single sources. `IT OPS` [S1]
- Deploy relevant Cisco Talos Snort rules on FTD when they are published for this CVE. The rules for the earlier CVE-2026-20349 were 46897 and 59654. `SOC` [S7] [S11]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Cisco PSIRT: Cisco Secure Firewall ASA and Secure Firewall Threat Defense Software Remote Access SSL VPN Tunnel Denial of Service Vulnerability (cisco-sa-asaftd-tunnel-dos-s6mgkb75)
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
Primary vendor advisory: fixed releases, mitigations, exploitation statement.

[S2] CVE Program (MITRE CVE API): CVE-2026-76418 record
Published 2026-10-28 · `A1` Completely reliable, confirmed by other sources
CNA Cisco record. Confirms the CVE ID the briefing could not corroborate, plus CVSS vector and CWE-690.

[S3] The Hacker News: Cisco Patches Actively Exploited ASA and FTD VPN Flaw That Can Crash Firewalls
Published 2026-10-29 · `B1` Usually reliable, confirmed by other sources
Briefing source. Matches the advisory on fixes and mitigations.

[S4] SecurityWeek: Attackers Exploit Second Cisco Firewall VPN Zero-Day Since August
Published 2026-10-29 · **B1** Usually reliable, confirmed by other sources
Briefing source. Links the flaw to CVE-2026-20349 and notes it is unclear whether the same actor exploited both.

[S5] BleepingComputer: New Cisco firewall zero-day exploited to crash SSL VPN devices
Published 2026-10-29 · **B2** Usually reliable, probably true
Adds the Shadowserver figure of more than 51,000 exposed ASA SSL VPN devices and the history of Cisco firewall exploitation.

[S6] GBHackers: Cisco Patches Actively Exploited SSL VPN Vulnerability Affecting ASA and FTD Firewalls
Published 2026-10-29 · **C2** Fairly reliable, probably true
Restates the advisory's configuration review guidance.

[S7] Cisco PSIRT: Cisco ASA and FTD Software Remote Access SSL VPN Denial of Service Vulnerability (cisco-sa-asaftd-vpn-dos-dzv4mQFF)
Published 2026-08-11 · **A1** Completely reliable, confirmed by other sources
Advisory for the related August zero-day CVE-2026-20349. Updated 2026-09-16.

[S8] CVE Program (MITRE CVE API): CVE-2026-20349 record
Published 2026-08-11 · **A1** Completely reliable, confirmed by other sources
CISA-ADP data shows the CVE was added to KEV on 2026-08-11.

[S9] CISA: Known Exploited Vulnerabilities Catalog (JSON feed, version 2026.10.28)
Published 2026-10-28 · **A1** Completely reliable, confirmed by other sources
CVE-2026-76418 was not listed in the catalog released 2026-10-28 19:00 UTC, just before Cisco's advisory.

[S10] FIRST: EPSS API query for CVE-2026-76418 and CVE-2026-20349
Published 2026-10-28 · **A2** Completely reliable, probably true
Returned a score only for CVE-2026-20349 (0.0101). No score yet for CVE-2026-76418.

[S11] CyCognito: Emerging Threat: (CVE-2026-20349) Cisco ASA and FTD Denial of Service via Remote Access SSL VPN
Published 2026-08-12 · **B2** Usually reliable, probably true
Covers the earlier flaw only. Source of detection and hardening guidance (Snort rules, reload monitoring, source restriction, HA pairs).

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2023-11-01	ArcaneDoor campaign against Cisco firewalls begins (later tied to CVE-2024-20353 and CVE-2024-20359), per BleepingComputer. The exact start day is approximate; only the month is reported.	[S5]
2025-09-25	Around this date (exact day approximate): CVE-2025-20333 and CVE-2025-20362 are exploited against ASA 5500-X devices, and CISA issues Emergency Directive 25-03.	[S5]
2026-08-11	Cisco discloses the exploited ASA/FTD SSL VPN DoS flaw CVE-2026-20349, and CISA adds it to KEV.	[S7] [S8]
2026-09-16	Cisco updates the CVE-2026-20349 advisory to version 1.1 (hardening releases supersede the hot fixes).	[S7]
2026-10-01	Sometime in October 2026 (exact date not disclosed), Cisco PSIRT becomes aware of active exploitation of CVE-2026-76418.	[S1]
2026-10-28	CISA releases KEV catalog version 2026.10.28 (19:00 UTC) without CVE-2026-76418. Cisco publishes advisory cisco-sa-asaftd-tunnel-dos-s6mgkb75 (19:15 GMT), and the CVE record is published (20:05 UTC).	[S1] [S2] [S9]
2026-10-29	The Hacker News, SecurityWeek, BleepingComputer and others report the exploited zero-day.	[S3] [S4] [S5]

Relevance to Indianapolis, Indiana & managed clients

Cisco ASA and FTD firewalls are common remote-access VPN gateways in Indiana. Users include county and municipal governments, school districts and universities, hospital systems and clinics, and Indianapolis-area manufacturers and small and mid-size businesses, many of whom rely on managed service providers. Secondary authentication on tunnel groups is often how organizations add MFA or certificate checks to AnyConnect/Secure Client logins, so the security-conscious setups are the ones most likely to be exposed. A forced reload cuts off remote clinicians, teleworking government staff, remote plant engineering and vendor support, and on a single-firewall site it can also drop all internet traffic. Managed IT providers should run the configuration check across every client firewall, schedule fixed-release upgrades (HA pairs first), and tell clients ahead of time about possible VPN interruptions. Public entities should expect CISA KEV and possible state guidance to follow.

Intelligence gaps

- Who is exploiting CVE-2026-76418, how widely, since when, and against which sectors. Cisco has not said.
- No IOCs, exploit request characteristics or crash signatures have been published. Watch for Cisco advisory revisions and Talos Snort rules.
- Whether the denial of service is being used to support other activity, such as disrupting logging or forcing failover during a wider intrusion. No reporting suggests this so far.
- Whether the same actor exploited both CVE-2026-20349 and CVE-2026-76418 (SecurityWeek says this is unclear).
- CISA KEV status and due date, and the EPSS score, for CVE-2026-76418 were pending as of 2026-10-29.
- How many of the more than 51,000 exposed ASA SSL VPN devices have secondary authentication configured and are therefore vulnerable.

Other notes

- The CVE ID in the briefing excerpt (CVE-2026-76418) is correct. It is confirmed by Cisco's advisory and the CVE record. CVE-2026-20349 is a separate August 2026 flaw with different fixed releases and its own KEV entry.
- Fixed releases for CVE-2026-76418 are later than the August fixes for CVE-2026-20349 in every train, so upgrading to the October fixed release addresses both, assuming cumulative trains. Confirm with Cisco Software Checker.
- GBHackers calls the flaw critical. Cisco rates it High (CVSS 8.6).
- The discovery is credited to Eric Fernald and came out of a Cisco TAC support case.
- Not affected: Cloud-delivered Firewall, cdFMC, Cisco Secure Access, and Secure Firewall Management Center.
- The same news cycle included other Cisco exploitation reports: UAT-11473 exploiting SD-WAN CVE-2026-20127 with the KeyDrift framework, and Secure Email Gateway CVE-2026-76519. These are separate products and are not linked to this flaw.

CTI-20261029-01 v1.0 · Generated 2026-10-29 08:35 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.